

# BuySellChain

Sistema d'Asta Trustless su Blockchain Hyperledger Fabric

Documento di Progettazione e Analisi di Sicurezza

**Salvucci Franco** (Mat. 0368692)  
**Ionut Georgian Zbirciog** (Mat. 0381279)

27 gennaio 2026

## Sommario

Il mercato immobiliare tradizionale è caratterizzato da inefficienze e dipendenza da intermediari. BuySellChain propone un sistema decentralizzato basato su **Blockchain** per eliminare l'agente immobiliare fisico. L'architettura su Hyperledger Fabric gestisce tramite Smart Contract la validazione delle offerte e il trasferimento della proprietà digitale. Il sistema garantisce trasparenza assoluta e azzeramento delle commissioni.

# Indice

|          |                                                  |           |
|----------|--------------------------------------------------|-----------|
| <b>1</b> | <b>Introduzione</b>                              | <b>2</b>  |
| <b>2</b> | <b>Architettura del Sistema</b>                  | <b>3</b>  |
| 2.1      | Gestione dell'Identità e Sicurezza . . . . .     | 4         |
| 2.2      | User Requirements Definition . . . . .           | 5         |
| 2.3      | Frontend . . . . .                               | 7         |
| 2.4      | Backend (Security Gateway) . . . . .             | 8         |
| 2.4.1    | Authentication & Authorization . . . . .         | 8         |
| 2.4.2    | Modello Dati & Interfaccia RESTful API . . . . . | 9         |
| 2.4.3    | Logica di Bussiness . . . . .                    | 14        |
| 2.5      | Blockchain Layer . . . . .                       | 16        |
| 2.6      | Database Off-Chain . . . . .                     | 17        |
|          | <b>Bibliografia</b>                              | <b>18</b> |

# Capitolo 1

## Introduzione

Il sistema **BuySellChain** mira a decentralizzare il mercato immobiliare tramite un servizio di aste online. Come verrà illustrato, l'agente si limita alla registrazione dell'asta e non svolge più il ruolo di intermediario tipico del modello tradizionale. In questa architettura, l'intermediazione è affidata alla Blockchain, incaricata di validare ogni offerta. Questo approccio garantisce trasparenza, sicurezza e una riduzione dei costi operativi, eliminando la necessità di intermediari tradizionali e consentendo agli utenti di partecipare direttamente al processo di compravendita.

La documentazione di questo progetto è organizzata come segue:

**Architettura del Sistema** Saranno presentate l'architettura e le tecnologie utilizzate, con particolare attenzione al backend e alla Blockchain.

**Analisi del Perimetro di Attacco** Verranno delineati il perimetro di attacco e le principali minacce.

**Possibili Attacchi e Come Difendersi** Infine, saranno discussi i possibili attacchi e le contromisure adottate per mitigarli.

# Capitolo 2

## Architettura del Sistema

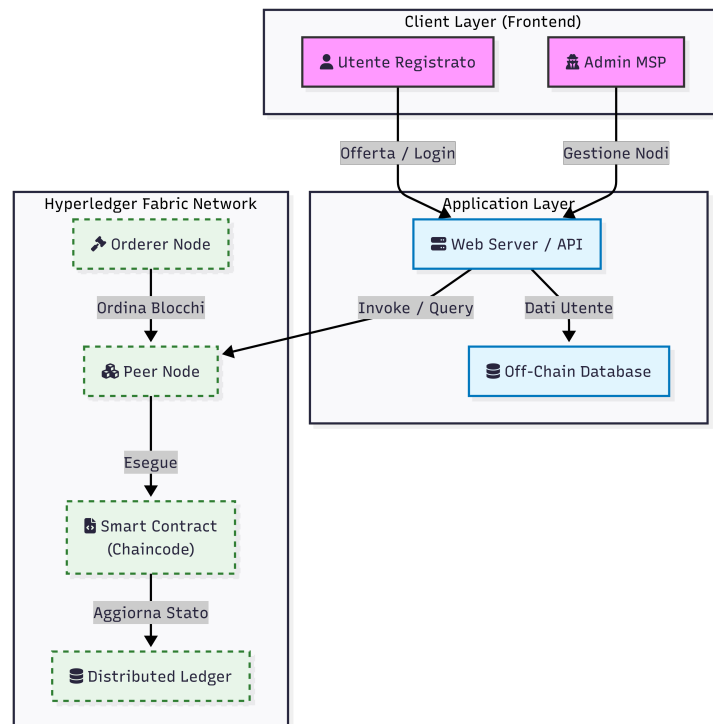
L'architettura di **BuySellChain** adotta un approccio ibrido che integra la flessibilità del Web 2.0 con la sicurezza del Web 3.0. Il sistema è progettato per garantire la disintermediazione della compravendita immobiliare, come richiesto dagli obiettivi di progetto.

**Frontend:** Interfaccia utente realizzata con **Jinja2** e **Alpine.js**, che fornisce reattività lato client senza richiedere una build pipeline complessa. La responsabilità è limitata alla presentazione dei dati e all'interazione utente, senza contenere logica di business critica.

**Backend (Security Gateway):** Server applicativo implementato in **Python** con il microframework **Flask**, che funge da middleware di sicurezza tra il client pubblico e la rete privata Blockchain. Questa componente ha il ruolo critico di sanitizzare gli input, gestire le sessioni, implementare il controllo degli accessi basato su ruoli (RBAC) e prevenire l'esposizione diretta delle API del Ledger. Si occupa dell'autenticazione degli utenti tramite credenziali verificate sul database off-chain e della generazione di JWT per l'autorizzazione stateless delle operazioni successive.

**Blockchain Layer:** Il nucleo del sistema, basato su **Hyperledger Fabric** [1], che funziona come database distribuito e immutabile per le operazioni critiche di compravendita. Questo livello è accessibile esclusivamente tramite il client Lisp fornito dal docente, che incapsula la logica di interazione con il chaincode e la gestione delle identità crittografiche (MSP). Il meccanismo di consenso distribuito valida le transazioni secondo le regole definite negli Smart Contract, garantendo l'integrità e la non-ripudiabilità delle operazioni.

**Database Off-Chain:** Un database relazionale **PostgreSQL** utilizzato per la persistenza dei dati sensibili e non critici per il consenso distribuito, come i profili utente, le credenziali di accesso al portale web e l'anagrafe del sistema. L'accesso è mediato attraverso **SQLAlchemy**, un'astrazione ORM che garantisce protezione contro attacchi SQL injection. Questa separazione garantisce la conformità alle normative sulla privacy (GDPR), evitando la scrittura di dati sensibili sul Ledger immutabile. Le password sono protette mediante l'algoritmo di hashing bcrypt con salt unico per ogni utente.



**Figura 2.1:** Schema ad alto livello dell'architettura ibrida Web 2.0 / Web 3.0

## 2.1 Gestione dell'Identità e Sicurezza

Poiché Hyperledger Fabric è una rete di tipo *permissioned*, a differenza delle blockchain pubbliche, tutti i partecipanti devono essere identificati e autorizzati prima di poter interagire con il ledger. In questo contesto, la fiducia non è anonima ma basata su identità crittografiche verificate.

Per gestire questo livello di autorizzazione, l'architettura si basa su un componente fondamentale:

**Definizione (*Membership Service Provider (MSP)*).** *L'MSP è il componente astratto del sistema che definisce le regole di validazione delle identità. Esso agisce come un'autorità di certificazione logica che consente alla rete di riconoscere e considerare affidabili i certificati digitali presentati dai peer e dagli utenti.*

Il funzionamento operativo coinvolge la cooperazione tra MSP e le *Certificate Authorities (CA)*:

1. **Rilascio dell'Identità:** Le CA generano una coppia di chiavi (pubblica e privata) e rilasciano un certificato X.509 che rappresenta l'identità digitale dell'attore.
2. **Verifica (Ruolo dell'MSP):** Quando un attore (es. un Peer) firma digitalmente una transazione usando la propria chiave privata, l'MSP interviene per verificare che tale certificato sia stato emesso da una CA fidata e che l'attore possieda i permessi necessari per quella specifica operazione (es. avallare una transazione).

In questo scenario, il client Lisp incapsula tale processo; di conseguenza l'attenzione è rivolta all'autenticazione dell'utente presso il server Web (Security Gateway).

## 2.2 User Requirements Definition

In questa sezione vengono definiti gli attori che interagiscono con la piattaforma **BuySell-Chain** e le azioni a loro consentite. Il sistema è progettato per operare in un ambiente *trustless* basato su Hyperledger Fabric, eliminando la necessità di intermediari umani nella fase di negoziazione.

### User Classes and Characteristics

**Amministratore di Sistema:** Gestisce la piattaforma, monitora anomalie e alert di sicurezza. Dispone di una dashboard dedicata per osservabilità, auditing e interventi correttivi.

**Utente Registrato:** Attore abilitato alla compravendita; lo stesso account può ricoprire ruoli distinti:

- **Venditore (Proprietario dell'asset):** Possiede l'immobile digitalizzato sul registro e avvia l'asta definendone i parametri.
- **Offerente (Bidder):** Partecipa all'asta inviando offerte firmate e vincolanti secondo le regole dello Smart Contract.

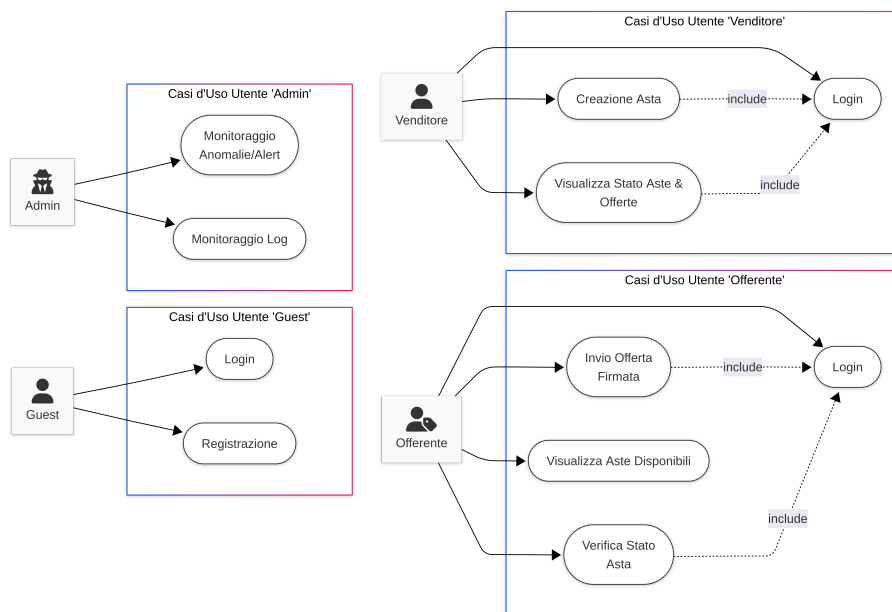
**Utente Non Autenticato:** Visitatore esterno. Senza account può consultare le aste e gli immobili pubblicati, senza possibilità di interazione avanzata.

### User Actions and Use Cases

Le azioni riflettono la logica di business gestita dal server Web e dagli Smart Contract.

- **Azioni Utente Non Autenticato:**
  - Consultare la landing page del progetto.
  - Registrarsi o accedere.
  - Effettuare un login sicuro.
- **Azioni dell'Amministratore (Monitoraggio e Sicurezza):**
  - Monitorare gli alert su tentativi di violazione dell'integrità (mismatch crittografici).
  - Analizzare i log delle offerte rifiutate per violazioni delle finestre temporali (anti-frontrunning).
- **Azioni dell'Utente Registrato — Venditore:**
  - Avviare un'asta per un immobile già digitalizzato.
  - Impostare la finestra temporale dell'asta (inizio/fine) gestita dallo Smart Contract.

- Visualizzare in tempo reale sul Ledger lo stato delle offerte ricevute.
- Ricevere la notifica di aggiudicazione e il trasferimento della proprietà digitale.
- **Azioni dell'Utente Registrato — Offerente:**
  - Consultare le aste immobiliari attive.
  - Inviare un'offerta firmata; lo Smart Contract verifica l'incremento minimo richiesto.
  - Verificare la propria posizione in graduatoria (anonimizzata o pubblica secondo la logica di business).
  - Visualizzare l'esito della validazione (accettata/rifiutata per motivi temporali o di importo).



**Figura 2.2:** Azioni degli utenti all'interno della piattaforma



## 2.3 Frontend

Per la realizzazione del frontend è stato adottato il motore di templating **Jinja2** [2], integrato nativamente in Flask, per la generazione dinamica delle pagine HTML lato server. Jinja2 consente di creare template modulari e riutilizzabili, separando la logica di presentazione dai dati applicativi e facilitando la manutenzione del codice.

Per l'interattività lato client, è stato scelto il framework leggero **Alpine.js** [3], che fornisce reattività senza richiedere una build pipeline complessa. Alpine.js permette di dichiarare il comportamento dinamico direttamente nel markup HTML mediante direttive semplificate, risultando ideale per applicazioni web moderne ma senza la complessità di framework come React o Vue.

Questa combinazione garantisce un frontend performante, mantenibile e facilmente integrabile con il backend Flask, preservando la semplicità dell'architettura complessiva.

Il frontend consiste delle seguenti route:

`/login` Pagina di autenticazione per l'accesso degli utenti registrati.

`/signin` Pagina di registrazione per i nuovi utenti.

`/` Pagina home nella quale vengono presentate tutte le aste disponibili in formato grid. Ogni card della griglia mostra la foto principale dell'immobile, il titolo dell'asta, il prezzo di partenza e lo stato. Gli utenti non autenticati possono consultare le aste ma non partecipare.

`/assets/register` Pagina dedicata alla registrazione di un nuovo immobile. Un venditore deve fornire le informazioni necessarie quali titolo, ubicazione, descrizione, foto principale e ulteriori dettagli catastali prima di poter procedere alla creazione dell'asta.

`/auctions/create` Pagina per la creazione di una nuova asta. Accessibile solo dai venditori che abbiano precedentemente registrato almeno un immobile. Consente di impostare i parametri temporali (data inizio e fine), il prezzo di partenza e l'incremento minimo.

`/auctions/{id}` Route dinamica generata per ciascun'asta. Visualizza i dettagli completi dell'immobile, lo stato dell'asta in tempo reale, la graduatoria delle offerte (ove applicabile) e consente agli utenti autenticati di partecipare inviando un'offerta.

`/profile` Pagina del profilo utente nella quale sono disponibili i dati personali, la cronologia delle aste create (per i venditori) e la cronologia delle offerte inviate (per gli offerenti).

## 2.4 Backend (Security Gateway)

In questa sezione verrà analizzato il backend insieme alla logica di business. Questa sezione descrive nel dettaglio il componente architetturale che funge da ponte sicuro tra l'interfaccia pubblica (Frontend) e la rete privata (Blockchain Layer). Il Security Gateway non si limita a inoltrare le richieste, ma implementa la logica applicativa necessaria per garantire l'integrità del sistema, la gestione delle identità e la validazione preliminare delle transazioni, proteggendo il Ledger da accessi non autorizzati o malformati.

La tecnologia scelta per l'implementazione del backend è **Python** [4], utilizzando il microframework **Flask** [5, 6]. Questa scelta è motivata dalla necessità di avere un ambiente di sviluppo rapido, flessibile e con un ecosistema ricco di librerie per la crittografia e la gestione delle reti. Il server Flask espone una serie di API RESTful che vengono consumate dal client Frontend.

### 2.4.1 Authentication & Authorization

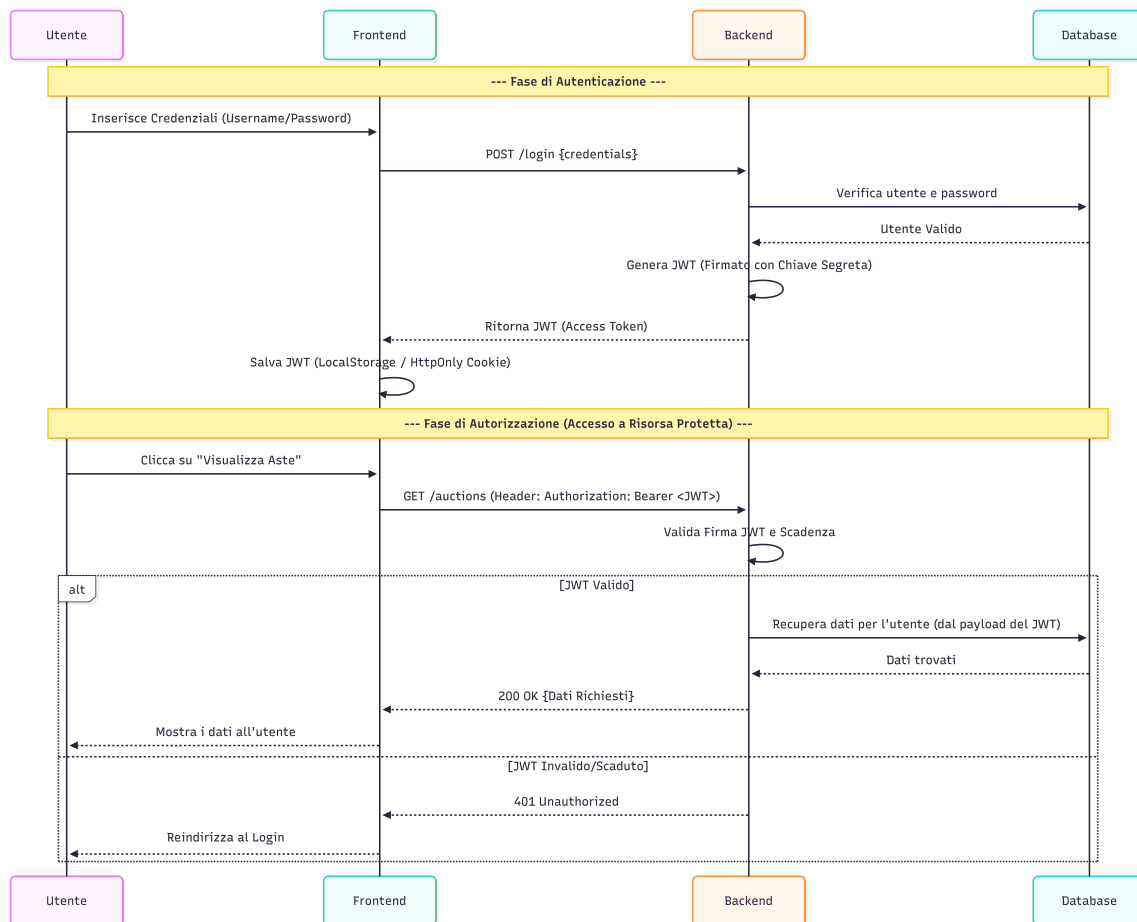
La sicurezza di **BuySellChain** si articola su due livelli distinti ma interconnessi: l'autenticazione degli utenti e la gestione dei permessi operativi.

- **Autenticazione (Identity Verification):** Il Security Gateway agisce come punto d'ingresso unico. Verifica le credenziali dell'utente (username e password) consultando il database off-chain. Una volta validata l'identità, il sistema mappa l'utente Web 2.0 a un'identità digitale riconosciuta dalla rete Fabric, garantendo che ogni operazione sul ledger sia tracciabile e attribuibile a un attore specifico.
- **Autorizzazione (Access Control):** Dopo l'autenticazione, il sistema applica politiche di controllo degli accessi basate sui ruoli (RBAC). Il backend verifica se l'utente possiede i privilegi necessari per invocare specifiche transazioni (es. solo un utente con ruolo "Venditore" può inizializzare un'asta).

Il Security Gateway funge da *Policy Enforcement Point*, intercettando le richieste e verificando che il richiedente possieda i privilegi necessari (es. solo il proprietario di un asset può metterlo all'asta) prima di inoltrare qualsiasi comando alla Blockchain.

Una volta completata con successo la fase di login, il server genera e firma un *JSON Web Token* (JWT) [7]. Questo token funge da passaporto digitale per l'utente e contiene, nel suo *payload*, informazioni essenziali quali l'identificativo utente, i ruoli assegnati e la data di scadenza della sessione.

Il client (Frontend) riceve il token e lo memorizza in modo sicuro. Per ogni successiva interazione con le API del sistema, il client deve includere il JWT nell'header della richiesta HTTP (solitamente nell'header **Authorization: Bearer <token>**). Questo meccanismo *stateless* permette al backend di validare l'identità del richiedente e verificare le autorizzazioni per ogni singola operazione senza dover interrogare continuamente il database delle credenziali.



**Figura 2.3:** Flusso di autenticazione/autorizzazione

## 2.4.2 Modello Dati & Interfaccia RESTful API

Poiché Hyperledger Fabric mantiene il world state come mappa di coppie (**key**, **value**), a livello applicativo è necessario definire: convenzioni di naming per le chiavi (namespace e identificatori), classi/entità applicative e un formato di serializzazione deterministico (es. JSON).

Le API di base fornite dal prof. Arcieri sono pubblicate come endpoint REST. Il Security Gateway riceve le richieste HTTP della piattaforma web e le traduce in comandi per il client Lisp verso la rete Fabric. Ad esempio, una chiamata HTTP `POST /api/v1/make_bid` viene mappata al comando `AddKV`. Il client invoca quindi le funzioni di *chaincode* per creare, leggere, aggiornare o eliminare coppie (**key**, **value**) sul ledger.

Le primitive disponibili sono:

**AddKV:** Inserisce una nuova coppia (**key**, **value**) in una classe applicativa.

**GetKV:** Restituisce il **value** associato a una **key** di una classe.

**GetKeyHistory:** Restituisce la cronologia immutabile delle operazioni su una **key**.

**DelKV:** Elimina la coppia (**key**, **value**) associata a una **key**.

**GetClasses:** Restituisce l'elenco delle classi disponibili.

**GetNumKeys:** Restituisce il numero di coppie presenti in una classe.

**GetKeys:** Restituisce l'elenco delle chiavi presenti in una classe.

**Listing 2.1:** Envelope di richiesta alle API base

```
1 {  
2   "cmd": "AddKV | GetKV | GetKeyHistory | DelKV | GetClasses |  
        GetNumKeys | GetKeys",  
3   "class": "NomeClasse",  
4   "key": ["NAMESPACE", "ID"],  
5   "value": { ... }  
6 }
```

## Definizione Modello Dati

Di seguito vengono presentate le definizioni strutturali delle classi dati che costituiscono il modello di persistenza distribuito. Ogni tabella rappresenta un'entità logica memorizzata in modo immutabile sulla Blockchain, specificando i campi, i tipi di dato e le relazioni chiare necessarie per garantire l'integrità referenziale e la tracciabilità delle operazioni di compravendita immobiliare all'interno del Ledger di Hyperledger Fabric.

| Campo            | Tipo          | Note                                |
|------------------|---------------|-------------------------------------|
| id               | string        | Identificativo univoco              |
| ownerId          | string        | Riferimento all'utente proprietario |
| title            | string        | Titolo descrittivo immobile         |
| location         | string        | Indirizzo fisico                    |
| description      | string        | Descrizione immobile                |
| currentAuctionId | string   null | ID dell'asta attiva (se presente)   |
| createdAt        | int (epoch)   | Data creazione                      |
| status           | enum          | ACTIVE, LOCKED, TRANSFERRED         |

**Tabella 2.1:** Definizione della Classe Asset

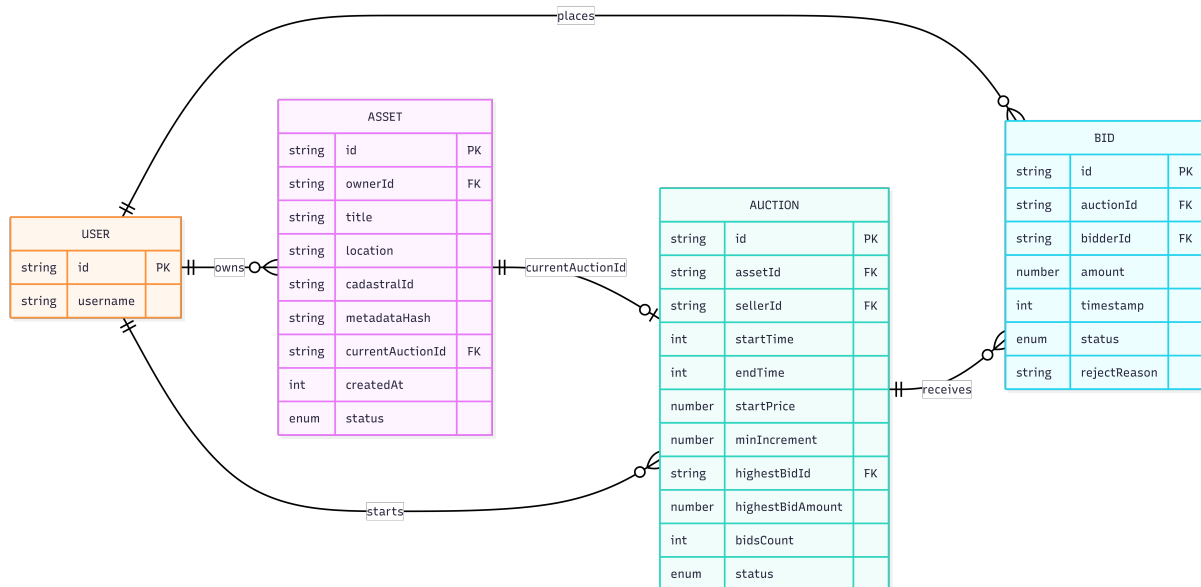
| Campo        | Tipo          | Note                                |
|--------------|---------------|-------------------------------------|
| id           | string        | Identificativo univoco offerta      |
| auctionId    | string        | Riferimento all'asta                |
| bidderId     | string        | Riferimento all'offerente           |
| amount       | number        | Importo offerto                     |
| timestamp    | int (epoch)   | Data e ora offerta                  |
| status       | enum          | ACCEPTED, REJECTED                  |
| rejectReason | string   null | Motivo del rifiuto (se applicabile) |

**Tabella 2.2:** Definizione della Classe Bid

Pertanto, ipotizzando un'analogia con le *tabelle SQL* per fini rappresentativi, la struttura delle classi può essere visualizzata come nello schema seguente:

| Campo            | Tipo          | Note                             |
|------------------|---------------|----------------------------------|
| id               | string        | Identificativo univoco dell'asta |
| assetId          | string        | Riferimento all'asset in vendita |
| sellerId         | string        | Riferimento al venditore         |
| startTime        | int (epoch)   | Data inizio asta                 |
| endTime          | int (epoch)   | Data fine asta                   |
| startPrice       | number        | Prezzo di partenza               |
| minIncrement     | number        | Incremento minimo rilancio       |
| highestBidId     | string   null | ID dell'offerta vincente attuale |
| highestBidAmount | number   null | Importo dell'offerta vincente    |
| bidsCount        | int           | Contatore totale offerte         |
| status           | enum          | ACTIVE, CLOSED, CANCELLED        |

**Tabella 2.3:** Definizione della Classe Auction



**Figura 2.4:** Schema logico delle tabelle su Fabric

La figura illustra le relazioni logiche tra le entità. L'utente (User) è l'attore principale: può possedere molteplici Asset, avviare diverse Auction e partecipare attivamente inviando Bid. Gli Asset possono essere associati a una Auction attiva (relazione 1:1 opzionale), mentre ogni Auction è legata univocamente a un bene specifico e funge da contenitore per tutte le offerte ricevute.

Questo modello relazionale, pur essendo implementato su un archivio chiave-valore non relazionale, è progettato per garantire la completa tracciabilità della filiera di vendita (provenance). Mantenendo riferimenti incrociati tra venditori, offerenti, beni e stati delle aste, il sistema permette di ricostruire in modo deterministico e immutabile l'intera cronologia di una transazione immobiliare, dall'inserimento dell'asset fino all'aggiudicazione finale, assicurando così la massima trasparenza e integrità dei dati.

## Definizione Interfaccia RESTful API

Definita la struttura logica dei dati, il passo successivo consiste nell'esposizione dell'interfaccia RESTful API. Nella fase attuale di sviluppo (sperimentale), il server Web è configurato per l'ascolto sulla porta locale standard 5000. L'endpoint base per tutte le richieste API è:

`http://localhost:5000/api/v1/`

Per ridurre la complessità infrastrutturale in ambiente di test, la comunicazione avviene attualmente su protocollo HTTP non cifrato.

I principali endpoint sono:

**POST /auth/signin** Registrazione di un nuovo utente. La richiesta crea un'identità sul database off-chain.

**POST /auth/login** Autenticazione utente. Verifica le credenziali e restituisce il token JWT necessario per autorizzare le chiamate successive.

**POST /assets** Registrazione di un nuovo immobile sul ledger. Richiede che l'utente sia autenticato e abbia il ruolo di "Venditore". Internamente invoca **AddKV** per la classe **Asset**.

**GET /assets/** Recupero dettagli di tutti gli assets. Internamente invoca **GetKeys** e **KetKV** per la classe omonima.

**GET /assets/{id}** Recupero dettagli di uno specifico asset. Internamente invoca **GetKV** per la classe omonima.

**POST /auctions** Creazione di una nuova asta per un asset posseduto dall'utente. Il sistema verifica la proprietà dell'asset e imposta lo stato iniziale dell'asta. Invoca **AddKV** per la classe **Auction**.

**GET /auctions** Elenco delle aste attive. Supporta filtri opzionali per stato o range di prezzo. Internamente utilizza **GetKeys** o query specifiche se supportate.

**POST /bids** Invio di un'offerta per un'asta attiva. La logica di backend verifica che l'asta sia aperta, che l'offerta superi l'importo corrente più l'incremento minimo, e che l'offerente non sia il venditore stesso. Se valida, registra l'offerta tramite **AddKV** sulla classe **Bid** e aggiorna lo stato dell'asta.

**GET /admin/users** Restituisce l'elenco completo degli utenti registrati nel database off-chain e il loro stato (attivo/sospeso), per permettere all'amministratore di gestire le utenze.

**GET /admin/stats** Fornisce metriche aggregate del sistema, come il numero totale di aste concluse, il volume delle transazioni e il numero di asset registrati, invocando **GetNumKeys** sulle diverse classi.

**GET /admin/history/{key}** Endpoint di auditing che espone la cronologia immutabile di una specifica chiave (asset o asta), invocando la primitiva **GetKeyHistory** del chaincode.

**Listing 2.2:** Esempio di richiesta AddKV per aggiungere un Asset

```
1 {
2   "cmd": "AddKV",
3   "class": "Asset",
4   "key": ["ASSET", "ASSET_1"],
5   "value": {
6     "id": "ASSET_1",
7     "ownerId": "USER_123",
8     "title": "Villa sul mare",
9     "location": "Via del lungomare 12",
10    "cadastralId": "a7bbcecb",
11    "metadataHash": "
12      e5990593c22e6647a7bbde8e85f395e56727a7bbd8ccecb6",
13    "currentAuctionId": "AUCTION_2",
14    "createdAt": 1769509800,
15    "status": "LOCKED"
16  }
17 }
```

**Listing 2.3:** Esempio di richiesta AddKV per creare un'asta

```
1 {
2   "cmd": "AddKV",
3   "class": "Auction",
4   "key": "auction:AUCTION_2",
5   "value": {
6     "id": ["AUCTION", "AUCTION_2"],
7     "assetId": "ASSET_1",
8     "sellerId": "USER_123",
9     "startTime": 1769509200,
10    "endTime": 1769516400,
11    "startPrice": 350000,
12    "minIncrement": 5000,
13    "highestBidId": null,
14    "highestBidAmount": null,
15    "bidsCount": 0,
16    "status": "ACTIVE"
17  }
18 }
```

**Listing 2.4:** Esempio di richiesta AddKV per aggiungere un'offerta (Bid)

```
1 {
2   "cmd": "AddKV",
3   "class": "Bid",
4   "key": ["bid", "BID_1"],
5   "value": {
6     "id": "BID_1",
7     "auctionId": "AUCTION_2",
8     "bidderId": "USER_456",
9     "amount": 355000,
10    "timestamp": 1769509500,
11    "status": "ACCEPTED",
12    "rejectReason": null
13  }
14 }
```

### 2.4.3 Logica di Bussiness

La piattaforma implementa un modello di gestione degli attori e delle aste articolato in fasi distinte:

**Registrazione e Verifica dei Venditori** Un utente che desideri partecipare alle aste come venditore deve completare una procedura di registrazione qualificata. Oltre alle informazioni anagrafiche standard (nome, cognome, email, numero di telefono), il sistema richiede l'inserimento del codice fiscale, necessario per garantire l'identificazione univoca e conforme alle normative sulla tracciabilità delle operazioni immobiliari. Una volta sottomessa la richiesta, un messaggio di notifica viene inviato agli amministratori del sistema, i quali hanno la responsabilità di validare l'identità del richiedente e approvare o rifiutare l'iscrizione al ruolo di venditore.

**Struttura Temporale delle Aste** Ogni asta è caratterizzata da un intervallo temporale definito dal venditore, durante il quale gli offerenti possono partecipare. Tale intervallo è suddiviso logicamente in finestre temporali di durata predeterminata, al fine di implementare meccanismi anti-frontrunning e garantire equità nella partecipazione.

**Vincoli sulle Offerte** Per ogni finestra temporale, ciascun offerente può inviare al massimo una sola offerta. Questa limitazione impedisce comportamenti speculativi e riduce la complessità computazionale del sistema. Le offerte rimangono nascoste agli altri partecipanti fino al termine della relativa finestra temporale, garantendo così l'anonimato del processo di bidding.

**Aggiornamento dello Stato dell'Asta** Al termine di ogni finestra temporale, il sistema esegue automaticamente un'operazione di consolidamento dello stato dell'asta:

- Vengono valutate tutte le offerte ricevute durante la finestra.
- I campi `highestBidAmount` e `bidsCount` vengono aggiornati per riflettere l'offerta vincente e il conteggio totale.
- Lo stato dell'asta transisce in `LOCKED`, impedendo temporaneamente l'invio di nuove offerte.
- Il venditore acquisisce la possibilità di modificare il parametro `minIncrement`, adattando dinamicamente il valore richiesto per i successivi rilanci.

Una volta completato l'aggiornamento, l'asta ritorna allo stato `ACTIVE`, rendendo di nuovo disponibile la partecipazione per la finestra temporale successiva.

L'intervallo temporale compreso tra `startTime` e `endTime` viene suddiviso in finestre temporali discrete secondo il seguente schema:

$$\text{window\_duration} = \frac{\text{endTime} - \text{startTime}}{n}$$

dove  $n$  rappresenta il numero totale di finestre temporali configurabili dal venditore al momento dell'inizializzazione dell'asta. Questo meccanismo garantisce una distribuzione equa degli intervalli di partecipazione e facilita l'implementazione di politiche anti-frontrunning,



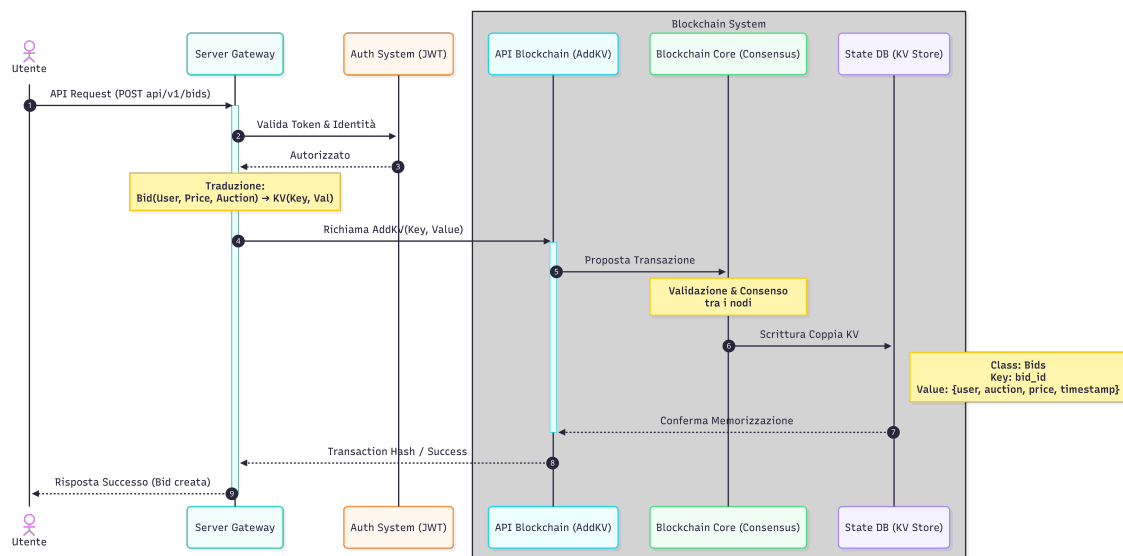
in quanto ogni finestra temporale costituisce un perimetro di validazione indipendente per le offerte ricevute.

## 2.5 Blockchain Layer

L'ultimo layer dell'architettura è rappresentato dalla blockchain Hyperledger Fabric, che svolge due ruoli fondamentali nel sistema: fungere da database distribuito e immutabile, e validare le transazioni effettuate dagli utenti secondo le regole definite negli Smart Contract.

In questo contesto, Fabric agisce come sistema di registrazione ufficiale (ledger) per tutte le operazioni critiche di compravendita: dalla registrazione degli asset immobiliari, alla creazione delle aste, fino alla registrazione delle offerte. La natura distribuita e permissioned della rete garantisce che ogni transazione sia validata da più peer secondo il meccanismo di consenso configurato, assicurando così l'integrità e la non-ripudiabilità delle operazioni.

Il Security Gateway comunica con la rete Fabric esclusivamente tramite il client Lisp fornito dal docente, che incapsula la logica di interazione con il chaincode e la gestione delle identità crittografiche (MSP). Questo isolamento protegge il ledger da accessi diretti e non autorizzati.



**Figura 2.5:** Flusso di azioni per la creazione di un'offerta

## 2.6 Database Off-Chain

Il database off-chain è responsabile della persistenza dei dati sensibili e delle informazioni anagrafiche degli utenti, garantendo che tali dettagli non vengano esposti direttamente sul Ledger immutabile. Il Security Gateway interagisce con questo componente per validare le credenziali di accesso e gestire i permessi, fungendo da ponte tra l'identità dell'utente sulla piattaforma web e il suo corrispettivo crittografico sulla rete Blockchain. La tecnologia adottata per l'implementazione è PostgreSQL [8].

| Campo          | Tipo          | Note                                                |
|----------------|---------------|-----------------------------------------------------|
| id             | string        | allineato a <code>user:&lt;uuid&gt;</code> on-chain |
| role           | array di enum | ADMIN, SELLER, BIDDER                               |
| name           | string        |                                                     |
| surname        | string        |                                                     |
| email          | string        |                                                     |
| birthday       | date          |                                                     |
| cellularNumber | number        |                                                     |
| passwordHash   | string        |                                                     |
| lastLoginAt    | int (epoch)   |                                                     |
| createdAt      | int (epoch)   |                                                     |

**Tabella 2.4:** Tabella Users

Per l'interazione con PostgreSQL nel contesto del framework Flask, è stata adottata la libreria **SQLAlchemy** [9], un'astrazione Object-Relational Mapping (ORM) che consente di operare su query strutturate anziché ricorrere a SQL puro. Questo approccio garantisce una maggiore sicurezza nei confronti di attacchi SQL injection e una migliore manutenibilità del codice.

Al fine di semplificare la gestione dell'infrastruttura di sviluppo e garantire la portabilità dell'applicazione, il database PostgreSQL è stato containerizzato mediante **Docker**. La configurazione del container è definita in un file `docker-compose.yml`, il quale specifica i parametri di connessione, il volume di persistenza dei dati e le variabili di ambiente necessarie. Questo approccio consente agli sviluppatori di avviare l'intera stack del database con un singolo comando, eliminando le dipendenze dall'ambiente locale e facilitando il deployment su sistemi eterogenei.

Per la messa in sicurezza delle credenziali è stato adottato l'algoritmo di hashing crittografico `bcrypt`, basato sul cifrario Blowfish. Il processo integra nativamente la generazione di un salt univoco per ogni utente, restituendo una stringa finale che concatena versione, costo, salt e digest secondo la struttura:

$$\text{pwd\_hash} = \$2b\$[\text{cost}][\$[\text{salt}]]\$[\text{hash}]$$

Questo approccio garantisce protezione contro attacchi di tipo rainbow table e attacchi a forza bruta grazie al fattore di costo adattivo.

# Bibliografia

- [1] The Hyperledger Foundation, *Hyperledger Fabric Documentation*. The Linux Foundation, 2024. Versione 2.5 LTS. Accesso: Gennaio 2026.
- [2] A. Ronacher, “Jinja2: A full-featured template engine for Python.” <https://jinja.palletsprojects.com/>, 2026. Accessed: 2026-02-12.
- [3] C. Porzio, “Alpine.js: A rugged, minimal framework for composing JavaScript behavior in your markup.” <https://alpinejs.dev/>, 2026. Accessed: 2026-02-12.
- [4] Python Software Foundation, “Python language reference, version 3.12,” 2023. Disponibile su python.org.
- [5] Pallets Projects, “Flask: A microframework for python based on werkzeug, jinja 2 and good intentions,” 2010. Versione 3.0.x.
- [6] L. Turner, “Flask-jwt-extended: Open source extension for flask adding support for json web tokens.” <https://github.com/vimalloc/flask-jwt-extended>, 2023.
- [7] M. B. Jones, J. Bradley, and N. Sakimura, “JSON Web Token (JWT).” RFC 7519, May 2015.
- [8] PostgreSQL Global Development Group, *PostgreSQL: The World’s Most Advanced Open Source Relational Database*. PostgreSQL Global Development Group, 2026. Accessed: 2026-02-09.
- [9] M. Bayer, “SQLAlchemy.” <https://www.sqlalchemy.org/>, 2026. Accessed: 2026-02-12.